Coinsult

Request your audit at **coinsult.net**

Advanced Manual

Smart Contract Audit

November 2, 2026

x.com/coinsultaudits

t.me/coinsult_tg

Audit requested by

FOBO Ecosystem

https://github.com/fobodotfun/src/ (31 of 31 files reviewed)

Global Overview

Manual Code Review

In this audit report we will highlight the following issues:

Vulnerability Level	Total	Pending	Acknowledged	Resolved
Informational	12	0	12	0
Low-Risk	12	0	10	2
Medium-Risk	2	0	0	2
Critical-Risk	0	0	0	0

Risk Classification

Coinsult uses certain vulnerability levels, these indicate how bad a certain issue is. The higher the risk, the more strictly it is recommended to correct the error before using the contract.

Vulnerability Level	Description
Informational	Does not compromise the functionality of the contract in any way
Low-Risk	Won't cause any problems, but can be adjusted for improvement
Medium-Risk	Will likely cause problems and it is recommended to adjust
Critical-Risk	Will definitely cause problems, this needs to be adjusted

Audit Summary

FOBO	
Website	fobo.fun
Blockchain	Robinhood Chain (chain ID 4663)
Source Code	https://github.com/fobodotfun/contracts/commit/2745e56d84aade01c468dca7d3109cf8d3adb428
Contract Address	

This audit report has been prepared by Coinsult's experts at the request of the client. In this audit, the results of the static analysis and the manual code review will be presented. The purpose of the audit is to see if the functions work as intended, and to identify potential security issues within the smart contract.

The information in this report should be used to understand the risks associated with the smart contract. This report can be used as a guide for the development team on how the contract could possibly be improved by remediating the issues that were identified.

Audit Scope

Coinsult was commissioned to perform an audit based on the provided code.

Note that we only audited the code available to us on this URL at the time of the audit. If the URL is not from any block explorer (main net), it may be subject to change. Always check the contract address on this audit report and compare it to the token you are doing research for.

Audit Method

Coinsult's manual smart contract audit is an extensive methodical examination and analysis of the smart contract's code that is used to interact with the blockchain. This process is conducted to discover errors, issues and security vulnerabilities in the code in order to suggest improvements and ways to fix them.

Automated Vulnerability Check

Coinsult uses software that checks for common vulnerability issues within smart contracts. We use automated tools that scan the contract for security vulnerabilities such as integer-overflow, integer-underflow, out-of-gas-situations, unchecked transfers, etc.

Manual Code Review

Coinsult's manual code review involves a human looking at source code, line by line, to find vulnerabilities. Manual code review helps to clarify the context of coding decisions. Automated tools are faster but they cannot take the developer's intentions and general business logic into consideration.

Used tools

- Slither: Solidity static analysis framework
- Remix: IDE Developer Tool
- CWE: Common Weakness Enumeration
- SWC: Smart Contract Weakness Classification and Test Cases
- DEX: Testnet Blockchains

Table of Contents

Global Overview 2
- Manual Code Review 2

Audit Summary 2

Audit Scope 3
- Audit Method 3
- Automated Vulnerability Check 3
- Manual Code Review 3
- Used tools 3

Table of Contents 4

● The Hook Has No Owner, No Upgrade Path And No Way To Withdraw Pool Liquidity

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I1	The claim that a FOBO pool's liquidity cannot be removed was checked rather than taken on trust. The hook inherits no ownership contract and carries no privileged function, there is no delegatecall, proxy or selfdestruct anywhere in the source, and the three callbacks that would let an outsider create a pool on this hook, add liquidity or donate are deliberately left reverting. The factory does have an owner, and its powers reach only future launches: pausing, fees, bands, the allowed quotes and the signer, with ownership two step and renouncing disabled. Update, November 2, 2026: Acknowledged by FOBO. No change was needed and none was made.

Code Snippet

```
// src/FoboHook.sol:34   contract FoboHook is HookClaims, IUnlockCallback
//                       no Owned, no onlyOwner anywhere in src/hook/

// src/base/BaseHook.sol:36  enabled only in order to refuse
function beforeInitialize(...) external virtual returns (bytes4) {
    revert Disabled();
}

// src/base/Owned.sol:13  the factory owner cannot walk away
function renounceOwnership() public pure override {
    revert RenounceDisabled();
}
```

Recommendation

No change needed. Keep the hook free of any owner or upgrade mechanism, since this property is the basis of the product's main claim.

The Launched Token Is A Plain Fixed Supply ERC-20

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I2	Every launch, $FOBO itself included, deploys this same unmodified OpenZeppelin ERC-20: a fixed supply of one billion minted once to the factory, which passes the whole amount to the hook as pool liquidity. There is no owner, no mint function, no transfer fee, no pause and no blocklist, so the supply cannot grow and no address can be frozen after launch, and holders can burn their own tokens, which the floor treats as permanently gone. The deployed $FOBO was checked rather than assumed: its creation and runtime bytecode are both an exact match for this contract, built with the compiler settings the project pins. Update, November 2, 2026: Acknowledged by FOBO. No change was needed and none was made.

Code Snippet

```
// src/FoboToken.sol:12
contract FoboToken is ERC20, ERC20Burnable, IFoboToken {
    uint256 public constant TOTAL_SUPPLY = 1_000_000_000e18;
    constructor(string memory name_, string memory symbol_)
        ERC20(name_, symbol_) {
        _mint(msg.sender, TOTAL_SUPPLY);
    }

// the deployed $FOBO, checked on chain 4663
0x000DE658153f47f23e92973C8EB1e89762703676
src/FoboToken.sol:FoboToken  exact match, creation + runtime
solc 0.8.26+commit.8a97fa7a, optimizer 200, cancun
```

Recommendation

No change needed.

Scope And Method, Including The Follow Up Of November 2026

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I3	The review covers the twenty seven Solidity files FOBO wrote, read line by line, with Uniswap v4 core and OpenZeppelin treated as trusted third party code outside the scope. The follow up compared the repository against the reviewed version file by file: twenty six of the twenty seven are byte identical, and the only difference is a function declaration and a comment added to one interface, so no reviewed contract was altered. The fixes sit instead in two new contracts, in on chain ownership and configuration, and in published documentation. The chain state was read directly and every configuration claim held, twenty one reads in all. The two new contracts were not reviewed and no test was executed, so a finding is marked resolved only where the evidence itself could be checked, not where it depends on code this review has not read.

Code Snippet

```
// the follow up, measured against the reviewed version
26 of 27 files byte identical
 1 of 27 changed: src/interfaces/IAggregatorV3.sol
         9 lines, a declaration and a comment, no logic

// present but not covered by this review
src/FoboFactoryGate.sol   160 lines
src/FoboBoundedFeed.sol    79 lines

// chain reads performed: 21 of 21 matched the claims
```

Recommendation

Review the two new contracts before the remaining medium finding is treated as closed; the ownership, delay, roles and feed wiring behind them are already confirmed.

● The Floor Price Is Monotone And The Absorb Guarantee Is Re-Checked After Every Change

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I4	The claim that the floor only moves up was traced rather than assumed. The search for a new floor is bounded above by the current floor less one tick spacing, so the stored floor tick can only move in the direction of a higher price, and there is no path anywhere that moves it the other way. Both the raise and the sweep end by recomputing what the positions actually hold against the circulating supply and reverting with FloorBroken if the floor could no longer buy every token back, and either path rolls back on its own without stopping trading. Update, November 2, 2026: Acknowledged by FOBO. No change was needed and none was made.

Code Snippet

```
// src/hook/HookFloor.sol:107   the search can never go below the floor
c.tHigh = tickF - SPACING;

// src/hook/HookFloor.sol:262   after a raise
if (_absorbNow(p, sNow) < _circulating(p, sNow)) revert FloorBroken();

// src/hook/HookFloor.sol:289   after a sweep
if (_absorbNow(p, c.sCur) < c.circulating) revert FloorBroken();
```

Recommendation

No change needed.

● The Fee Cap On A Limit Order Applies Per Fill, Not To The Order As A Whole

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I5	An order carries a maximum fee per fill, and nothing limits how many fills an order can be split into, so the total a keeper can take is that figure multiplied by however many fills it chooses to make rather than the single number the owner set. What actually protects the owner is the all-in limit check, which counts the fee as part of what was spent and so refuses a fill whose fee ate the price, and the protection holds. The name is still likely to be read as a cap on the whole order. Update, November 2, 2026: FOBO reports the field is now labelled as a maximum per fill, with a line saying an order can fill in parts.

Code Snippet

```
// src/FoboLimitOrders.sol:170  per fill, not per order
if (fee > order.maxFeePerFill || (buy && fee >= amountIn))
    revert FeeTooHigh();
```

Recommendation

Label it as a per fill cap wherever the order is placed, and consider tracking fees paid against a per order total so the figure the owner sets is the figure they pay.

● The Exit Guarantee At The Floor Holds But Carries No Explicit Margin

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I6	The band of quote under the price is the last bid in the pool, since no liquidity exists above its far edge, so whether a holder can always sell rests entirely on the check that the band can absorb the whole circulating supply. That check is set up conservatively, with the supply figure rounded up against the pool and the capacity figure rounded down, so the real capacity exceeds the real float and the last holder can get out. There is no margin beyond that rounding, and because a swap must fill completely or revert, a seller who asks for more than the pool can give is refused outright rather than filled in part. Update, November 2, 2026: FOBO added both recommended fuzz tests. They are present and assert that the seller's balance reaches zero, which fails on any revert or partial fill. They were not executed as part of this review.

Code Snippet

```
// src/hook/HookFloor.sol:262  the guarantee
if (_absorbNow(p, sNow) < _circulating(p, sNow)) revert FloorBroken();

// src/hook/HookTax.sol:97  a sell must fill completely
if (delta.amount1() != params.amountSpecified) revert PartialFill();
```

Recommendation

Add a fuzz test that sells the entire circulating supply into the floor, once as a single swap and once as many small ones, and assert that neither reverts; then size the band with a small explicit margin so the guarantee does not rest on rounding direction alone.

● The Locker Cannot Be Touched By Anyone And The Buyback Is Bounded Against Sandwiching

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I7	Two things worth recording as they stand. The vesting contract has no owner, no upgrade path and no early exit, it records what actually arrived rather than what was requested so a token that takes a cut on transfer is locked correctly, and anyone can trigger a release but it only ever pays the beneficiary. The buyback's $FOBO purchase is bounded against the pool's tick at the start of the block rather than the price just before the swap, so an attacker who moves the price first uses up the allowance themselves, and what they could still gain is below the tax they would pay going in and out. Update, November 2, 2026: Acknowledged by FOBO. No change was needed and none was made.

Code Snippet

```
// src/FoboVesting.sol:38  locks what actually arrived
uint256 received = IERC20(token).balanceOf(address(this)) - before;

// src/FoboBurner.sol:141  bounded from the block's start
uint160 sBound = TickMath.getSqrtPriceAtTick(
    h.startOfBlockTick(id) - BURN_MAX_TICKS);
if (sNow < sBound) revert BurnBound();
```

Recommendation

No change needed.

● The Declared Surface Matches The Code And Nothing Is Left Dangling

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I8	Every contract inherits the interface that describes it, the hook included, so the surface integrators build against is enforced by the compiler rather than kept in step by hand. Across all twenty seven files there is no error declared that cannot be reached and no event declared that is never emitted, so the revert reasons and the monitoring surface the interfaces document are the ones the deployed code actually produces. The interface comments were checked against behaviour on the points that carry weight, including that a pay token's pricing is copied into an order at placement so a later owner change cannot reach an open one, and that the burner's withdrawal power is stated plainly where it is declared rather than buried. Update, November 2, 2026: Acknowledged by FOBO. No change was needed and none was made.

Code Snippet

```
// src/hook/HookStorage.sol:24  the hook's surface is enforced
abstract contract HookStorage is BaseHook, IFoboHook {

// src/interfaces/IFoboBurner.sol:41  stated where it is declared
/// @notice Sends everything held of `token`, its ERC-6909 claims
///         redeemed, to `to`. Owner only.

// 0 unused errors and 0 unemitted events across src/
```

Recommendation

No change needed.

● The Guard Against Transfer Hooks Is Narrower Than The Comment Claims

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I9	The gate sets a flag for the length of the probe's transfer and refuses any call that arrives while it is set, which is a neat way to catch a token that hands control back during a transfer. The comment describes this as nothing being able to call the gate while the transfer runs, and that is wider than the code: the two step ownership functions the gate inherits, and every view, carry no such guard. Nothing exploitable follows, because no standard token hook calls those and the usual ones land on the fallback and are refused, but the guarantee as written is not quite the one implemented.

Code Snippet

```
// src/FoboFactoryGate.sol:52  the claim
/// Every function of the gate: a quote's transfer code that reaches
/// any of them is a hook on transfer.

// inherited from Ownable2Step, without notProbing
transferOwnership(address)   acceptOwnership()
owner()   pendingOwner()
```

Recommendation

Either put the guard on the inherited entry points as well, or narrow the comment to say which calls it covers.

● The Probe Cannot See A Quote Token That Can Change After It Passes

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I10	The probe establishes how a token behaved during one transfer and across one waiting window. A quote served from behind an upgradeable proxy can behave correctly for both and change afterwards, at which point it is already allowed and the probe is not repeated. The contract is candid about two other blind spots, a token that calls its payer rather than the gate and a rebase that nets to zero across the window, but this one is not among them even though it is the easiest of the three to arrange.

Code Snippet

```
// src/FoboFactoryGate.sol:21  the stated limits
/// What a probe can't see: a quote that calls the payer rather than
/// the gate, or a rebase that nets to zero over the window.
```

Recommendation

Add an upgradeable quote to the stated limits, and keep the manual review step for whether a quote's code can change under it.

The Bound Applies To One Of The Feed's Two Accessors

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I11	The range and jump checks sit on the call that reports the latest round. The historical accessor forwards whatever the source returns with no checking at all, so anyone reading past rounds through this contract gets the raw feed while believing it is bounded. Nothing in FOBO is affected, because the limit orders contract reads only the latest round. Separately, the jump check treats any failure from the source as a missing round, so a source that fails for some other reason quietly turns the check off rather than refusing the price.

Code Snippet

```
// src/FoboBoundedFeed.sol:72  no checks on this path
function getRoundData(uint80 _roundId) external view returns (...) {
    return source.getRoundData(_roundId);
}

// src/FoboBoundedFeed.sol:66  every failure is read as a phase change
} catch { }
```

Recommendation

Apply the range check to the historical accessor too, and let the jump check distinguish a missing round from a source that failed for another reason.

Both New Contracts Are Ownerless Or Minimal Where It Matters

Informational *- Does not compromise the functionality of the contract in any way*
[Status: Acknowledged]

Error Code	Description
FOBO-I12	Worth recording as they stand. The bounded feed has no owner and every setting is fixed at deployment, so the limits cannot be widened later by anyone, and an absurd previous answer makes the comparison overflow and revert rather than pass, which fails in the safe direction. The gate holds no ether, answers no unexpected call, and its reasoning about which block counter applies on this chain is worked out explicitly and measured rather than assumed, with the contrast against the hook's own counter written down.

Code Snippet

```
// src/FoboBoundedFeed.sol:18  nothing settable
/// No owner and nothing settable: the bounds are the deployment.

// src/FoboFactoryGate.sol:28  the block counter, reasoned out
/// On Robinhood Chain (an Arbitrum chain) block.number is Ethereum's
/// block number, one every ~12 s ... so 7,200 of them is a day
```

Recommendation

Confirm once against mainnet that this chain's block.number does advance at about twelve seconds, since the waiting period is a day only if it does.

● The Creator's Launch Buy Is Exempt From The Tax Every Other Early Buyer Pays

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L1	For the first sixty seconds of a pool the swap tax starts at ninety percent and falls to two and a half, which is what stops a sniper taking the launch. The creator's own buy, made by the factory inside the launch transaction, is excluded from that curve and pays the base two and a half percent on up to five percent of the supply. The exclusion is correctly scoped, since it only covers the factory on the pool being launched and is cleared when the launch ends, and it does hand the creator an advantage over every other buyer in the same block that the public description of the launch tax does not mention. Update, November 2, 2026: FOBO reports the exemption is now disclosed on the public site and on the launch form. That sits outside the code and was not verified here.

Code Snippet

```
// src/FoboHook.sol:92  createPool marks the pool as launching
bytes32 slot = LAUNCHING_SLOT;
assembly ("memory-safe") { tstore(slot, id) }

// src/hook/HookTax.sol:114  _rate
if (sender == factory) {
    if (launching == PoolId.unwrap(id)) return (BASE_TAX, false);
}
return Tax.rate(block.timestamp - p.launchedAt);  // 90% -> 2.5%
```

Recommendation

State plainly in the public documentation that the creator's launch buy pays the base rate rather than the launch tax, so buyers can price that in.

Every Launch After The First Rests On One Hot Signing Key

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L2	Apart from the owner's own first launch, a token can only be created with a signature from the start signer, which the code comment describes as a hot key on the site's server. That signature is what binds a launch to the name, ticker and start price the site approved, so anyone holding the key can create launches that never passed the site's checks, including tokens named to impersonate something else, for the cost of the launch fee. The start band bounds the price such a launch can open at, and rotating the key voids outstanding signatures, but there is no second approval and no delay on the key itself. Update, November 2, 2026: FOBO moved the signing key into a hardware module. The signer set on chain is exactly the address derived from their published public key, so those two agree, but that the private key cannot be exported rests on their own report.

Code Snippet

```
// src/FoboFactory.sol:188  _useStart
if (err != ECDSA.RecoverError.NoError || signer != startSigner)
    revert BadStartSignature();

// src/FoboFactory.sol:298  setStartSigner
function setStartSigner(address signer) external onlyOwner { ... }
```

Recommendation

Keep the signer key in a hardware signer or a service that enforces the same checks the site does, monitor TokenLaunched for launches the site did not originate, and rotate on any doubt.

A Floor Raise That Fails Is Swallowed And The Block Is Marked Done Anyway

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L3	The raise runs inside a try and catch so that a fault in it can never stop people trading, which is the right choice. The cost is that a raise which reverts only emits an event, and the block is still recorded as settled, so nothing retries until the next block and nothing on chain forces anyone to notice. Since the floor rising is the product's central promise, it can stop working while swaps carry on looking normal, and every block's first swapper keeps paying for the failed attempt. Update, November 2, 2026: FOBO reports that every RaiseFailed event now alerts their admins and that a repeat on one pool is treated as an incident. The alerting lives in a private repository and could not be checked.

Code Snippet

```
// src/hook/HookTax.sol:40  beforeSwap
if (p.lastRaiseBlock != bn) {
    if (_plan(p, id).go) {
        try this.raiseFromHook{gas: RAISE_GAS}(key) {}
        catch (bytes memory reason) { emit RaiseFailed(id, reason); }
    }
    p.lastRaiseBlock = uint64(bn);   // set even when the raise failed
}
```

Recommendation

Alert on every RaiseFailed event and treat a repeat on the same pool as an incident, since nothing else surfaces it.

A Swap Reverts Unless It Carries Roughly 1.2 Million Gas

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Resolved]

Error Code	Description
FOBO-L4	Before it will run the floor raise or the fee split, the hook checks that the transaction still holds the whole budget for each and reverts with NeedGas if not. Reserving the gas up front is deliberate, so that a wallet's estimate includes the work rather than quietly skipping it, and it does mean a swap can need about 1.2 million gas on a block where both paths fire and far less on every other block. A router or aggregator that sizes its gas from a simulation taken on a quiet block will have its transactions revert on the block that matters, and the same applies to a holder trying to sell at the floor on a busy day, since the block's first seller is the one who pays for the raise. Update, November 2, 2026: Fixed and verified. The repository's README now carries the worst case gas figure and tells integrators to estimate on a block where the raise fires.

Code Snippet

```
// src/hook/HookTax.sol:42
if (gasleft() < RAISE_GAS * 64 / 63 + 40_000) revert NeedGas();
// src/hook/HookTax.sol:184
if (gasleft() < CREDIT_GAS * 64 / 63 + 20_000) revert NeedGas();

// src/hook/HookStorage.sol:67  RAISE_GAS  = 700_000
// src/hook/HookStorage.sol:72  CREDIT_GAS = 400_000
```

Recommendation

Document the worst case gas for a swap on a FOBO pool in the integration notes, and tell integrators to estimate on a block where the raise fires rather than taking the cheapest simulation.

The Referral On A Swap Is Credited To tx.origin

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L5	Unless the swap came from the limit order contract, the hook credits the referral to the transaction's origin, which for anyone using a smart contract wallet or a bundled transaction is the bundler rather than the person trading. A referred user who swaps through such a wallet silently loses their referrer's share, which goes to the team instead, and if a bundler's own address is ever bound to a referrer then every swap it relays credits that referrer. Referrers are bound once by the registrar and cannot sign themselves up, which keeps this to misattribution rather than theft. Update, November 2, 2026: FOBO accepts this and will not change it, since the hook has no upgrade path. The behaviour is written up in the README's integration notes.

Code Snippet

```
// src/hook/HookTax.sol:198  _trader
if (sender == limitOrders) return abi.decode(hookData, (address));
return tx.origin;

// src/FoboRevenue.sol:93  the referrer is looked up from that address
address referrer = referrerOf[trader];
```

Recommendation

Let a router or wallet pass the trader in hookData the way the limit order contract does, from a list of senders the owner trusts, and fall back to the transaction origin only for direct swaps.

● Floor Money Beyond What Holders Can Carry Leaves The Token And Buys $FOBO

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L6	A pool's floor only ever holds what its circulating tokens could sell into at the next tranche's price, and anything above that is swept out. Where it goes depends on the pool: a launched token's surplus buys and burns $FOBO, so tax paid by buyers of one token supports a different one, while $FOBO's own pool has no creator and its surplus is booked to the team as revenue instead. The guarantee that every circulating token can still sell into the floor is preserved and re-checked either way, and the published description of the floor does not mention that a surplus leaves the pool at all. Update, November 2, 2026: FOBO reports the sweep is now disclosed on the public site. That sits outside the code and was not verified here.

Code Snippet

```
// src/hook/HookFloor.sol:174  _planDrain
// floor money beyond what the circulating tokens can carry leaves

// src/hook/HookStorage.sol:168  _burnShare
if (p.creator == address(0)) {
    teamOwed[quote] += amount;   // $FOBO's own pool: to the team
} else if (q == fobo) {
    IFoboToken(q).burn(amount);  // a launched token: burns $FOBO
}
```

Recommendation

Say in the public description of the floor that a surplus beyond what the circulating supply can absorb leaves the pool, and that in $FOBO's own pool it becomes team revenue rather than a buyback.

● A Compromised Registrar Key Can Divert A Quarter Of The Protocol Fee

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L7	One address, the site's relayer, decides which trader is credited to which referrer, and a referrer currently earns a quarter of the protocol fee on that trader's swaps. If that key is taken, the holder can bind every trader who has no referrer yet to their own address and collect on all of them until the key is rotated. Recovery works and was clearly designed for, but it is rotate the key and then clear the bindings two hundred traders at a time, and anything already credited stays claimable by whoever it was booked to. Update, November 2, 2026: FOBO moved the registrar key into a hardware module and alerts on bulk registrations. The registrar set on chain matches the address derived from their published public key, but the custody claim rests on their own report.

Code Snippet

```
// src/FoboRevenue.sol:151  registerBy
if (msg.sender != registrar) revert NotRegistrar();
referrerOf[t] = r;   // set once, never changes after that

// src/FoboRevenue.sol:95  what that is worth
if (referrer != address(0))
    toReferrer = protocolFee * referralBps / BPS;  // 25%

// src/FoboRevenue.sol:267  recovery, 200 traders per call
function clearReferrers(address[] calldata traders) external onlyOwner
```

Recommendation

Keep the registrar key in a signer that cannot sign unattended batches, alert on any registerBy call that binds many traders to one referrer, and hold new referrers' share unclaimable for a short window so a bad batch can be cleared before it is paid.

● The Price Feed Is Checked For Staleness But Not For A Wrong Answer

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Resolved]

Error Code	Description
FOBO-L8	The feed handling is careful: it refuses a negative or zero answer, a missing or future timestamp, an answer older than the configured age, and it checks the sequencer uptime feed with a grace period. What it does not do is sanity check the size of the answer, so a feed that reports a fresh but badly wrong price, which is what happens when an aggregator pins at its own floor or ceiling, is used as if it were correct. Every limit order fill settles against that number, and the burner reads the same feed to decide whether a stablecoin route paid out fairly, so one wrong answer affects both contracts. Update, November 2, 2026: FOBO put a new contract, FoboBoundedFeed, in front of the feed. Confirmed on chain and since reviewed: it is wired in, its source is the Chainlink feed they named, and its limits are USD 100, USD 100,000 and 5000 basis points. What those limits actually catch is raised separately as FOBO-L12.

Code Snippet

```
// src/FoboLimitOrders.sol:202  _price
(, int256 answer,, uint256 updatedAt,) = p.feed.latestRoundData();
if (answer <= 0) revert FeedPriceInvalid();
// staleness and the sequencer are checked, the size is not

// src/FoboBurner.sol:174  the same feed bounds the peg check
uint256 ethUsd = IFoboLimitOrders(h.limitOrders()).ethUsd();
```

Recommendation

Store a plausible range per pay token and revert outside it, or compare the answer against the previous round and refuse a move larger than the feed's own deviation threshold allows in that time.

● A Limit Order Fills At Its Limit And The Keeper Keeps Everything Above It

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L9	The keeper chooses when to fill an order, how much of it to fill, which pools to route through and what fee to take, and the only thing checked on chain is that the owner ends up with at least the limit they set. That check is well built, measured from the owner's actual balance change and rounded against the keeper, so an owner can never do worse than their limit. They also can never do better: if the market has moved far past the limit, the keeper can route the fill so the owner receives exactly their limit and keep the rest, which is the opposite of how people expect a limit order to behave. Update, November 2, 2026: FOBO reports the order form now states that a fill pays the limit price and that their keeper returns any improvement to the owner. That sits outside the code and was not verified here.

Code Snippet

```
// src/FoboLimitOrders.sol:200  _allIn, the only bound on a fill
if (FullMath.mulDivRoundingUp(amountIn, price, unit)
        > FullMath.mulDiv(amountOut, order.limitPriceUsdE18, WAD))
    revert LimitNotMet();

// src/FoboLimitOrders.sol:156  the keeper picks all of it
function fill(uint256 id, uint256 amountIn, uint256 fee,
              Hop[] calldata route) external
```

Recommendation

Say in the order interface that a fill pays the limit price rather than the market price, or pass a share of the surplus back to the order's owner so the keeper is not the only party that benefits from a favourable move.

● Anyone Can Stop A New Quote From Being Listed For The Price Of A Dust Transfer

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L10	Admitting a quote takes a probe, then a day's wait, then a check that the gate still holds exactly the amount the probe pulled. That last check reads the gate's whole balance of the token, so it cannot tell a rebase from a transfer anyone else made. Since the probe emits an event, anyone watching can send a single unit of the quote to the gate and the approval reverts for the rest of the window. Clearing it means disallowing the quote, sweeping the balance and probing again, and the same unit of dust blocks it once more, so a listing can be held up indefinitely at almost no cost.

Code Snippet

```
// src/FoboFactoryGate.sol:91  allow
uint256 balance = IERC20(quote).balanceOf(address(this));
if (balance != s.balance) revert SampleDrifted(s.balance, balance);

// src/FoboFactoryGate.sol:80  which announces the window
emit Probed(quote, amount, block.number);
```

Recommendation

Hold the sample where only the gate can pay into it, such as a small holder contract created per quote, so an outside transfer cannot touch the balance being watched.

● The Owner Can Take The Factory Back Out Of The Gate With No Delay

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L11	The gate only constrains the factory for as long as it owns it, and the owner can hand that ownership to any address it likes in a single call. Once the new owner accepts, the quote setting is reachable directly again and the probe no longer applies to anything. There is no delay on this and no notice period, which is a different standard from the burner, where the same owner must wait forty eight hours in public before anything moves. The check therefore guards against a careless listing rather than a deliberate one.

Code Snippet

```
// src/FoboFactoryGate.sol:125  handFactoryTo
function handFactoryTo(address to) external notProbing onlyOwner {
    Ownable2Step(address(factory)).transferOwnership(to);
}

// src/FoboFactory.sol:325  what it reopens
function setQuoteAllowed(address quote, bool allowed) external onlyOwner
```

Recommendation

Put this one function behind the same timelock the burner uses, so stepping out of the gate carries the same public notice as reaching the buyback funds.

● The Feed's Bounds Do Not Catch The Failure They Are Named For

Low-Risk *- Won't cause any problems, but can be adjusted for improvement*
[Status: Acknowledged]

Error Code	Description
FOBO-L12	The interface says the range check is there for an aggregator pinned at its floor or ceiling, which is what a Chainlink aggregator does when the market leaves the range it was configured with. The check only catches that if the pinned number happens to fall outside one hundred to one hundred thousand dollars, and an aggregator's own floor can sit comfortably inside that. The jump check does not help either, because a pinned feed reports the same number every round, so the move from the previous round is zero and it passes. The project's own test pins only outside the band, and shows an answer exactly on either limit passing through.

Code Snippet

```
// src/interfaces/IFoboBoundedFeed.sol:12  what it claims to catch
/// an aggregator pinned at its floor or ceiling, or a broken one

// src/FoboBoundedFeed.sol:59  what it checks
if (answer < minAnswer || answer > maxAnswer) revert AnswerOutOfRange(answer);

// test/BoundedFeed.t.sol:70  a pin on the limit is allowed through
source.setAnswer(MIN); (, int256 a,,,) = noJump.latestRoundData();
assertEq(a, MIN);
```

Recommendation

Read the source aggregator's own minAnswer and maxAnswer and refuse any answer at or next to them, so a pin is caught wherever it sits, rather than choosing a fixed range and hoping the pin falls outside it.

A Quote Token Is Admitted On The Owner's Judgement With No On Chain Check

Medium-Risk *- Will likely cause problems and it is recommended to adjust*
[Status: Resolved]

Error Code	Description
FOBO-M1	Allowing a new pair checks only that a start band exists and that the token answers decimals() with at least six. Nothing tests whether the quote takes a fee on transfer, rebases, or calls back into the caller during a transfer, and the code comment states that ruling those out is a manual review step. A quote that takes a fee would leave the PoolManager short when the factory settles, so the creator's launch buy reverts, and a launch with no creator buy still succeeds and leaves behind a pool that no one can trade through correctly. A quote that calls back on transfer also hands control to the payer in the middle of the launch callback. Update, November 2, 2026: FOBO reports that a new contract, FoboFactoryGate, now owns the factory and runs this check on chain. The ownership was confirmed on chain and the gate has since been reviewed: its probe does test for a fee on transfer, for the common transfer hooks and for a rebase. What it still leaves open is raised separately as FOBO-L10 and FOBO-L11.

Code Snippet

```
// src/FoboFactory.sol:325  setQuoteAllowed
if (allowed && quote != address(0) && quote != fobo) {
    if (c.bandLow == 0 && c.bandHigh == 0) revert NoBand();
    c.decimals = _decimalsOf(quote);   // the only token check
}
c.allowed = allowed;
```

Recommendation

Probe a candidate quote on chain before allowing it: send a known amount to the contract and require the received balance to match, and reject a token whose balance changes without a transfer. Keep the manual review as well, and publish which quotes are allowed.

● The Owner Can Withdraw Every Launch Fee And Sweep Held For The $FOBO Buyback

Medium-Risk *- Will likely cause problems and it is recommended to adjust*
[Status: Resolved]

Error Code	Description
FOBO-M2	Every launch fee and every swept floor amount destined for the $FOBO buy-and-burn collects in the burner, and the owner can send all of it to any address at any time with no cap, no delay and no restriction on the recipient. The contract's own summary says nothing a keeper does can send anything anywhere but into $FOBO that is burned, which is true of keepers and not of the owner, so the one mechanism by which $FOBO is meant to accrue value rests on the owner choosing not to use this function. It is owner-only behind a two-step Safe and it cannot reach a pool's floor or anyone's wallet, which is why this is not rated higher. Update, November 2, 2026: FOBO moved the burner behind a timelock, and this was read off the chain rather than taken on trust: the owner is the timelock, the handover completed, the minimum delay is 172800 seconds, and the Safe holds no admin role over it, so nothing reaches these funds without forty eight hours of public notice.

Code Snippet

```
// src/FoboBurner.sol:256  emergencyWithdraw
function emergencyWithdraw(address token, address to)
    external onlyOwner
{
    uint256 claims =
        poolManager.balanceOf(address(this), c.toId());
    if (claims != 0) poolManager.unlock(...);  // the claims
    uint256 balance = c.balanceOfSelf();
    if (balance != 0) c.transfer(to, balance); // and the ETH
}

// src/FoboFactory.sol:143  where the launch fee goes
```

```
(bool sent,) = burner.call{value: spent}("");

// read on chain, 2026-11-02
burner.owner()        0xEbcC...1B35  the timelock
burner.pendingOwner() empty, the handover completed
timelock.getMinDelay() 172800 seconds, 48 hours
timelock admin role held by the Safe: no
```

Recommendation

Put this function behind a timelock long enough for holders to react, or restrict it to a recovery address fixed at deploy, and state plainly in the public material that the buyback funds are owner-recoverable.

Disclaimer

This audit report has been prepared by Coinsult's experts at the request of the client. In this audit, the results of the static analysis and the manual code review will be presented. The purpose of the audit is to see if the functions work as intended, and to identify potential security issues within the smart contract.

The information in this report should be used to understand the risks associated with the smart contract. This report can be used as a guide for the development team on how the contract could possibly be improved by remediating the issues that were identified.

Coinsult is not responsible if a project turns out to be a scam, rug-pull or honeypot. We only provide a detailed analysis for your own research.

Coinsult is not responsible for any financial losses. Nothing in this contract audit is financial advice, please do your own research.

The information provided in this audit is for informational purposes only and should not be considered investment advice. Coinsult does not endorse, recommend, support or suggest to invest in any project.

Coinsult can not be held responsible for when a project turns out to be a rug-pull, honeypot or scam.